



إجراءات الاستجابة لحوادث أمن المعلومات (Information Security Incident Response Procedure)

تصنيف الوثيقة	داخلي / مقيد (Internal / Restricted)
مرجع الوثيقة	ISMS-DOC-A05-26-1
الإصدار	1.0
التاريخ	12 September 2026
مؤلف الوثيقة	بشار الشراوي
مالك الوثيقة	(CISO) سارة الحربي – مديرة أمن المعلومات

سجل المراجعات (Revision History)

الإصدار	التاريخ	مؤلف المراجعة	ملخص التغييرات
1.0	2026-09-12	بشار الشراوي	الإصدار الأول – إجراءات الاستجابة للحوادث لبنك الأفاق الرقمية

Information Security Incident Response Procedure
(Internal / Restricted) داخلي / مقيد

التوزيع (Distribution)

المسمى الوظيفي	الاسم
قائدة الفريق – (CISO) مديرة أمن المعلومات	سارة الحربي
مدير تقنية المعلومات (CIO)	فهد العتيبي
مدير المراجعة الداخلية	أحمد الغامدي
مديرة الشؤون القانونية	ليلي الدوسري
مدير الموارد البشرية	خالد الشمري
فريق العمليات الأمنية	SOC فريق
—	فريق الاستجابة للحوادث

الاعتماد (Approval)

التاريخ	التوقيع	المنصب	الاسم
2026-09-12	_____	رئيس مجلس الإدارة	عبدالله المحيسن
2026-09-12	_____	الرئيس التنفيذي	نورة القحطاني

المحتويات (Contents)

1	المقدمة	9
2	مخطط تدفق الاستجابة للحوادث	10
3	اكتشاف الحادثة وتحليلها	11
3.1	تقييم الأثر	11
3.2	تحديد أولوية الحادثة	11
4	تفعيل إجراء الاستجابة للحوادث	13
5	تشكيل فريق الاستجابة للحوادث	14
5.1	أعضاء فريق الاستجابة للحوادث	14
5.2	الأدوار والمسؤوليات	15
5.2.1	قائد الفريق	15
5.2.2	ميسر الفريق	15
5.2.3	ضابط اتصال الحوادث	15
5.2.4	تقنية المعلومات	15
5.2.5	العمليات التشغيلية	16
5.2.6	إدارة المرافق	16
5.2.7	الصحة والسلامة	16
5.2.8	الموارد البشرية	16
5.2.9	تخطيط استمرارية الأعمال	16
5.2.10	الاتصالات (العلاقات العامة والعلاقات الإعلامية)	16
5.2.11	الشؤون القانونية والتنظيمية	17
5.3	مصفوفة تحديد المسؤوليات RACI	17
5.4	إدارة الحوادث ومراقبتها والاتصال	18
5.5	إجراءات الاتصال	18
5.5.1	الاتصالات الخارجية	19
5.5.2	الاتصال مع وسائل الإعلام	19
6	احتواء الحوادث والقضاء عليها والتعافي والإشعارات	21
6.1	الاحتواء	21
6.2	القضاء على الحادثة	22
6.3	التعافي	22
6.4	الإشعار والتبليغ	23
7	أنشطة ما بعد الحادثة	24
8	الملحق أ: ورقة جهات اتصال الاستجابة الأولية	25
9	الملحق ب: جهات الاتصال الخارجية المفيدة	26
10	الملحق ج: جدول أعمال الاجتماع القياسي لفريق الاستجابة للحوادث	27

الأشخاص والأشكال (Figures)

الشكل 1: مخطط تدفق الاستجابة للحوادث 10

الجدول (Tables)

الجدول 1: أولويات الحوادث 12
الجدول 2: أعضاء فريق الاستجابة للحوادث 14
الجدول 3: مصفوفة تحديد المسؤوليات (RACI) 17
الجدول 4: المتحدثون باسم وسائل الإعلام 20
الجدول 5: ورقة جهات اتصال الاستجابة الأولية 25
الجدول 6: جهات الاتصال الخارجية المفيدة 26

1 المقدمة (Introduction)

هذه الوثيقة مخصصة للاستخدام عند حدوث حادثة من أي نوع تؤثر على أمن المعلومات في بنك الآفاق الرقمية. وهي تهدف إلى ضمان استجابة سريعة وفعالة ومنظمة لحوادث أمن المعلومات.

يجب استخدام الإجراءات المنصوص عليها في هذه الوثيقة كإرشاد فقط عند الاستجابة لحادثة. لا يمكن التنبؤ بالطبيعة الدقيقة للحادثة وتأثيرها بدرجة معينة من اليقين، لذلك من المهم استخدام درجة جيدة من الحس السليم عند تحديد الإجراءات التي يجب اتخاذها..

أهداف إجراء الاستجابة للحوادث هي:

الهدف	الوصف
1	تقديم نظرة موجزة عن كيفية استجابة بنك الآفاق الرقمية لحادثة تؤثر على أمن معلوماته
2	تحديد من سيستجيب لحادثة وأدوارهم ومسؤولياتهم
3	وصف المرافق الموجودة للمساعدة في إدارة الحادثة
4	تحديد كيفية اتخاذ القرارات بشأن استجابتنا لحادثة
5	شرح كيفية التعامل مع الاتصالات داخل البنك ومع الأطراف الخارجية
6	تقديم تفاصيل الاتصال بالأشخاص الرئيسيين والوكالات الخارجية
7	تحديد ما سيحدث بعد حل الحادثة وإيقاف المستجيبين.

سيتم إعطاء جميع أعضاء الموظفين المذكورين في هذه الوثيقة نسخة يجب أن تكون متاحة لديهم عند الحاجة.

سيتم فحص تفاصيل الاتصال وتحديثها ثلاث مرات على الأقل سنوياً. يجب إرسال التغييرات في تفاصيل الاتصال أو التفاصيل الأخرى ذات الصلة التي تحدث خارج هذه الفحوصات المجدولة إلى information.security@bank-alafaq.com.sa في أقرب وقت ممكن بعد حدوث التغيير.

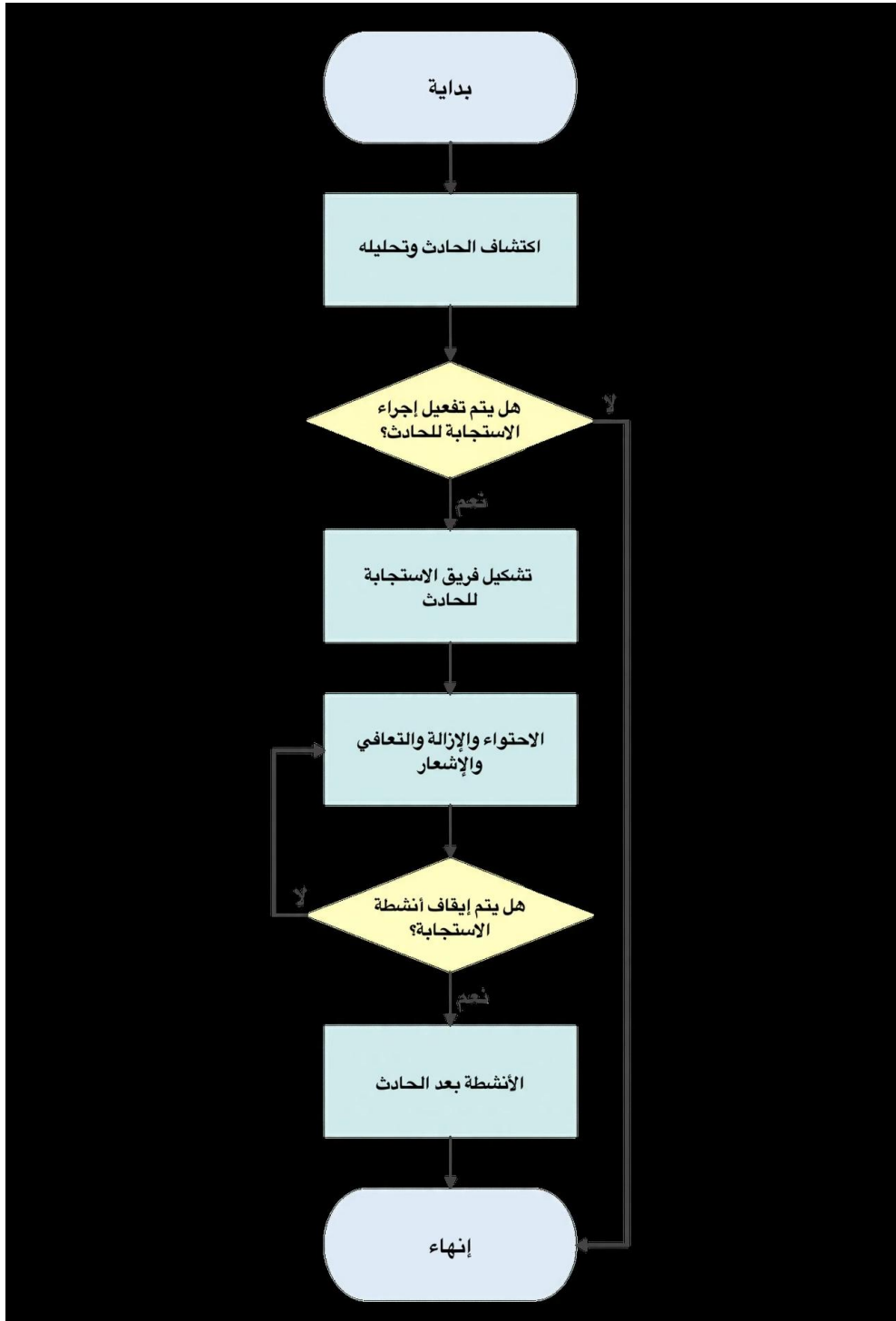
سيتم استخدام جميع المعلومات الشخصية التي تم جمعها كجزء من إجراء الاستجابة للحوادث والواردة في هذه الوثيقة فقط لأغراض إدارة حوادث أمن المعلومات وتخضع لتشريعات حماية البيانات ذات الصلة.. (PDPL)

2 مخطط سير الاستجابة للحوادث (Incident Response Flowchart)

مخطط سير إجراء الاستجابة للحوادث موضح في الرسم البياني أدناه :

Figure 1: Incident response flowchart

تم شرح هذه الخطوات بمزيد من التفصيل في الجزء المتبقي من هذا الإجراء.



اكتشاف الحادثة وتحليلها (Incident detection and analysis)

قد يتم اكتشاف الحادثة في البداية بطرق متنوعة ومن خلال عدة مصادر مختلفة، اعتماداً على طبيعة الحادثة وموقعها. قد يتم الكشف الذاتي عن بعض الحوادث عبر أدوات البرمجيات المستخدمة في بنك الأفاق الرقمية أو من قبل الموظفين الذين يلاحظون نشاطاً غير عادي. قد يتم إخطار الآخرين من قبل طرف ثالث مثل عميل أو مورد أو وكالة إنفاذ القانون.

من غير غير المعتاد أن يكون هناك تأخير بين أصل الحادثة واكتشافها الفعلي؛ أحد أهداف نظام إدارة أمن المعلومات (ISMS) هو تقليل هذه الفترة الزمنية. العامل الأكثر أهمية هو أنه يجب بدء إجراء الاستجابة للحوادث في أقرب وقت ممكن بعد الاكتشاف.

تقييم الأثر (Impact assessment)

بمجرد اكتشاف الحادثة، يجب إجراء تقييم أولي للأثر (عادةً من قبل فريق العمليات الأمنية (SOC) لتحديد الاستجابة المناسبة).

يجب أن يقدر تقييم الأثر هذا:

الوصف	البند
بما في ذلك أجهزة الحاسوب والشبكات والمعدات والإقامة	مدى التأثير على البنية التحتية لتقنية المعلومات
أو التي تم اختراقها	أصول المعلومات التي قد تكون معرضة للخطر
أي متى قد تكون بدأت	المدة المحتملة للحادثة
ومدى التأثير عليها	وحدات الأعمال المتأثرة
—	مؤشر أولي للسبب المحتمل للحادثة

يجب توثيق هذه المعلومات بحيث يكون هناك فهم واضح قائم على الوقت للوضع كما يظهر للاستخدام الحالي والمراجعة اللاحقة.

يجب إنشاء قائمة بأصول المعلومات وأنشطة الأعمال والمنتجات والخدمات والفرق والعمليات الداعمة التي قد تكون تأثرت بالحادثة مع تقييم لمدى التأثير.

تحديد أولوية الحادثة (Incident prioritisation)

بناءً على تقييم الأثر، سيتم تعيين أولوية للحادثة: عالية، متوسطة، أو منخفضة.

سيتم استخدام الإرشادات الواردة في الجدول أدناه عند تحديد الأولوية.

الأولوية	الوصف	أمثلة لبنك الأفق
High عالية	تعطيل كبير فعلي أو محتمل للعمل	• اكتشاف برمجيات خبيثة تنتشر عبر الشبكة • اكتشاف وصول غير مصرح به إلى كميات كبيرة من البيانات السرية • موقع الخدمات المصرفية الإلكترونية غير متاح للعملاء بسبب هجوم حجب خدمة محتمل
Medium متوسطة	تعطيل محلي يؤثر على مجالات أعمال متعددة	• نظام واحد غير متاح • الشبكة تعمل ببطء • فقدان قرص صلب مشفر
Low منخفضة	إزعاج محلي يؤثر على مستخدم واحد	• خرق بسيط لسياسة أمن المعلومات • تنبيه فيروس على جهاز حاسوب واحد • مشاركة كلمة مرور لنظام أقل حساسية

Table 1: Incident priorities

نتيجة لهذا التحليل الأولي، فإن فريق العمليات الأمنية SOC أو أي عضو في فريق الإدارة لديه السلطة للاتصال بقائد فريق الاستجابة للحوادث في أي وقت لطلب منه تقييم ما إذا كان ينبغي تنشيط إجراء الاستجابة لحوادث أمن المعلومات.

4 تفعيل إجراء الاستجابة للحوادث (Activating the incident response procedure)

بمجرد إخطار قائد الفريق بحادثة، يجب أن يقرر ما إذا كان حجم الحادثة وتأثيرها الفعلي أو المحتمل يبرر تنشيط إجراء الاستجابة للحوادث وعقد فريق الاستجابة للحوادث (IRT).

سيتم إجراء تقييم أولي للأثر بالفعل من قبل فريق SOC ، ولكن المزيد من الإرشادات لقائد الفريق بشأن ما إذا كان ينبغي بدء استجابة رسمية للحدث لأي حادثة معينة هي إذا انطبق أي مما يلي:

الوصف	المعيار
—	فقدان كبير فعلي أو محتمل للمعلومات المصنفة
—	تعطيل كبير فعلي أو محتمل لعمليات الأعمال
—	خطر كبير على سمعة البنك
—	أي موقف آخر قد يسبب تأثيراً كبيراً على البنك

في حالة وجود خلاف أو عدم يقين حول ما إذا كان ينبغي تنشيط استجابة الحادث، يكون قرار قائد الفريق نهائياً. إذا تقرر عدم تنشيط الإجراء، فيجب إنشاء خطة للسماح باستجابة منخفضة المستوى للحادثة ضمن قنوات الإدارة العادية. إذا كانت الحادثة تستدعي تنشيط إجراء IR ، فسيبدأ قائد الفريق في تجميع IRT .

5 تشكيل فريق الاستجابة للحوادث (Assemble incident response team)

بمجرد اتخاذ قرار تنشيط إجراء الاستجابة للحوادث، سيضمن قائد الفريق (أو النائب) الاتصال بجميع أصحاب الأدوار وإبلاغهم بطبيعة الحادثة.

5.1 أعضاء فريق الاستجابة للحوادث (Incident response team members)

سيُتألف فريق الاستجابة للحوادث عموماً من الأشخاص التالية أدوارهم مع نوابهم المذكورين:

النائب	شاغل الدور الرئيسي	الدور / مجال العمل
CIO – فهد العتيبي	CISO – سارة الحربي	Team Leader (قائد الفريق)
أخصائي حوكمة	مدير حوكمة أمن المعلومات	Team Facilitator (منسق الفريق)
SOC مهندس	SOC مدير	Incident Liaison (ضابط الاتصال) (بالحادث)
مدير البنية التحتية	CIO – فهد العتيبي	Information Technology (تقنية) (المعلومات)
مدير فرع الرياض	مدير العمليات المصرفية	Business Operations (عمليات) (الأعمال)
مدير الأمن المادي	مدير المرافق والخدمات	Facilities Management (إدارة) (المرافق)
نائب مسؤول السلامة	مسؤول الصحة والسلامة	Health and Safety (الصحة) (والسلامة)
مدير شؤون الموظفين	HR Manager – خالد الشمري	Human Resources (الموارد البشرية)
BCP منسق	مدير استمرارية الأعمال	Business Continuity Planning (استمرارية الأعمال)
مدير الاتصال المؤسسي	مدير التسويق وتجربة العملاء	Communications (PR & Media)
مستشار قانوني	ليلي الدوسري – مديرة الشؤون القانونية	Legal and Regulatory (القانوني) (والتنظيمي)

Table 2: Incident response team members

تفاصيل الاتصال للأعضاء المذكورين أعلاه مدرجة في الملحق أ من هذه الوثيقة.

5.2 الأدوار والمسؤوليات (Roles and responsibilities)

مسؤوليات الأدوار داخل فريق الاستجابة للحوادث هي كما يلي:

5.2.1 قائد الفريق (Team leader)

- يقرر ما إذا كان سيبدأ استجابة
- يجمع فريق الاستجابة للحوادث
- الإدارة الشاملة لفريق الاستجابة للحوادث
- يعمل كواجهة مع مجلس الإدارة وأصحاب المصلحة رفيعي المستوى
- صانع القرار النهائي في حالات الخلاف

5.2.2 ميسر الفريق (Team facilitator)

- يدعم فريق الاستجابة للحوادث
- ينسق الموارد داخل مركز القيادة / غرفة الحرب
- يستعد للاجتماعات ويسجل الإجراءات والقرارات
- يطلع أعضاء الفريق على آخر المستجدات عند عودتهم إلى مركز القيادة
- يسهل الاتصال عبر البريد الإلكتروني والفاكس والهاتف أو طرق أخرى
- يراقب مصادر المعلومات الخارجية مثل الأخبار

5.2.3 ضابط اتصال الحوادث (Incident liaison)

- يحضر موقع الحادثة في أقرب وقت ممكن
- يقيم مدى وتأثير الحادثة
- يقدم رواية مباشرة للوضع إلى IRT
- يتواصل مع IRT بشكل مستمر لتقديم التحديثات والإجابة على أي أسئلة مطلوبة لاتخاذ القرار

5.2.4 تقنية المعلومات (Information technology)

- يقدم مدخلات حول القضايا المتعلقة بالتقنية
- يساعد في تقييم الأثر

5.2.5 العمليات التشغيلية (Business operations)

- يساهم في اتخاذ القرار بناءً على معرفة عمليات الأعمال والمنتجات والخدمات
- يطلع أعضاء الفريق الآخرين على القضايا التشغيلية
- يساعد في تقييم التأثير المحتمل على عملاء البنك.

5.2.6 إدارة المرافق (Facilities management)

- يتعامل مع جوانب الأمن المادي والوصول
- يوفر وجوداً أمنياً إذا لزم الأمر

5.2.7 الصحة والسلامة (Health and safety)

- يقيم المخاطر على الحياة والأطراف
- يضمن تلبية المسؤوليات القانونية للصحة والسلامة دائماً
- يتواصل مع خدمات الطوارئ مثل الشرطة والإطفاء والطوارئ الطبية
- ينظر في القضايا البيئية فيما يتعلق بالحادث

5.2.8 الموارد البشرية (Human resources)

- يقيم ويقدم المشورة بشأن سياسة الموارد البشرية ومسائل عقود العمل
- يمثل مصالح موظفي البنك
- يقدم المشورة بشأن قضايا الكفاءة والتأديب

5.2.9 تخطيط استمرارية الأعمال (Business continuity planning)

- يقدم المشورة بشأن خيارات استمرارية الأعمال
- يستدعي خطط استمرارية الأعمال إذا لزم الأمر

5.2.10 الاتصالات [العلاقات العامة والعلاقات الإعلامية] (Communications [PR and media relations])

- مسؤول عن ضمان فعالية الاتصالات الداخلية
- يقرر مستوى وتكرار ومحتوى الاتصالات مع الأطراف الخارجية مثل وسائل الإعلام
- يحدد نهج إبقاء الأطراف المتأثرة على علم، مثل العملاء والمساهمين

5.2.11 الشؤون القانونية والتنظيمية (Legal and regulatory)

- يقدم المشورة بشأن ما يجب القيام به لضمان الامتثال للقوانين والأطر التنظيمية ذات الصلة
- يقيم الآثار القانونية الفعلية والمحتملة للحادثة والإجراءات اللاحقة
- يتواصل مع شركات التأمين لتقييم المطالبة والحصول على موارد إضافية

5.3 RACI مصفوفة (RACI matrix):

يوضح الجدول أدناه من هو المسؤول (R)، المساءل (A)، المستشار (C) أو المُخطر (I) في مراحل مختلفة من الإجراء.

TASK (المهمة)	TL	TF	IL	IT	BO	FM	HS	HR	CP	CO	LR	EM
اكتشاف الحادثة (Incident detection)	A	R	R	I	C		R				I	I
تحليل الحادثة (Incident analysis)	A	R	R	C	C	C	C			I	C	I
تشكيل فريق الاستجابة للحوادث (Assemble incident response team)	A	R	C	C	C	C	C	C	C	C	I	I
الاحتواء (Containment)	A	R	R	C	R	R	R			I	I	I
القضاء على الحادثة (Eradication)	A	R	R	C	R	R	R	I	C	I	I	I
التعافي (Recovery)	R	C	C	C	A	R	R		C	C	I	C
الاتصالات – الداخلية (Communication – internal)	A	C	C	C	C	C	C	C	R	C	R	C
الاتصالات – الخارجية (Communication – external)	A	C	C	C	C	C	C	C		R	C	I
الإشعار، على سبيل المثال مكتب مفوض المعلومات (Notification, for example, ICO)	A	C	C	R	C	C	C	C	I	C	R	I
تقرير الحادثة (Incident report)	A	R	C	C	C	C	C	C	C	I	C	C
مراجعة ما بعد الحادثة (Post-incident review)	A	R	C	C	C	C	C	C	C	I	C	C

Table 3: RACI matrix

المفتاح:

TL: قائد الفريق (Team Leader)

TF: ميسر الفريق (Team Facilitator)

IL: ضابط اتصال الحوادث (Incident Liaison)

BO: العمليات التشغيلية (Business Operations)

IT: تقنية المعلومات (Information Technology)

FM: إدارة المرافق (Facilities Management)

HS: الصحة والسلامة (Health and Safety)

HR: الموارد البشرية (Human Resources)

CP: تخطيط استمرارية الأعمال (Business Continuity Planning)

CO: الاتصالات (Communications)

LR: الشؤون القانونية والتنظيمية (Legal and Regulatory)

EM: الموظفون (Employees)

5.4 إدارة الحوادث، المراقبة والاتصالات (Incident management, monitoring and communication)

بمجرد تحديد استجابة مناسبة للحادثة، يحتاج IRT إلى أن يكون قادراً على إدارة الاستجابة الشاملة، ومراقبة حالة الحادثة، وضمان الاتصال الفعال على جميع المستويات.

يجب عقد اجتماعات IRT منتظمة بوتيرة مناسبة يقررها قائد الفريق. الغرض من هذه الاجتماعات هو ضمان إدارة موارد إدارة الحوادث بفعالية واتخاذ القرارات الرئيسية بسرعة، بناءً على معلومات كافية. سيتم تدوين محضر كل اجتماع من قبل منسق الفريق.

سيقدم ضابط الاتصال بالحدث تحديثات إلى IRT بوتيرة يقررها قائد الفريق. يجب تنسيق هذه التحديثات مع اجتماعات IRT.

5.5 إجراءات الاتصال (Communication procedures)

من الحيوي الحفاظ على اتصالات فعالة بين جميع الأطراف المشاركة في الاستجابة للحدث.

اعتماداً على الموقف، قد تكون وسيلة الاتصال الافتراضية أثناء الحادثة وجهاً لوجه، أو عبر الهاتف، أو عبر أدوات التعاون مثل Microsoft Teams ، يحددها قائد الفريق. لا ينبغي استخدام البريد الإلكتروني إلا بعد الحصول على إذن من IRT.

يجب اتباع الإرشادات التالية في جميع الاتصالات:

الوصف	لإرشاد
—	كن هادئاً وتجنب المحادثات الطويلة
إحالة طلبات المعلومات إلى IRT	أبلغ أعضاء الفريق الداخليين بالحاجة
اسأل إذا كان جهة الاتصال متاحة في مكان آخر، وإذا تعذر الاتصال اترك رسالة، ولا تقدم تفاصيل الحادثة	إذا تم الرد على مكالمة من شخص آخر
والردود والإجراءات	وثق دائماً تفاصيل وقت المكالمة

يجب تسجيل جميع الاتصالات بوضوح ودقة لأن السجلات قد تكون مطلوبة كجزء من الإجراءات القانونية في تاريخ لاحق.

5.5.1 الاتصال الخارجي (External communication)

اعتماداً على الحادثة، قد يكون هناك مجموعة متنوعة من الأطراف الخارجية التي سيتم التواصل معها. من المهم إدارة المعلومات التي يتم إصدارها لأطراف ثالثة بحيث تكون في الوقت المناسب ودقيقة.

يجب تمرير المكالمات التي لا تكون من وكالات مشاركة مباشرة في الاستجابة للحدث (مثل وسائل الإعلام) إلى عضو IRT المسؤول عن الاتصالات.

قد يكون هناك عدد من الأطراف الخارجية الذين، على الرغم من عدم مشاركتهم مباشرة في الحادثة، قد يتأثرون بها ويحتاجون إلى التنبيه لهذه الحقيقة. قد يشمل هؤلاء:

الطرف	—
العملاء	—
الموردون	—
المساهمون	—
الهيئات التنظيمية	—
الجهات الرقابية	—
شركات التأمين	—

5.5.2 الاتصال مع وسائل الإعلام (Communication with the media)

بشكل عام، ستكون استراتيجية الاتصال فيما يتعلق بوسائل الإعلام هي إصدار تحديثات عبر الإدارة العليا. لا ينبغي لأي عضو من الموظفين إجراء مقابلة مع وسائل الإعلام إلا إذا كان ذلك مصرحاً به مسبقاً من قبل IRT.

الواجهة المفضلة مع وسائل الإعلام ستكون إصدار بيانات صحفية مكتوبة مسبقاً. في ظروف استثنائية، سيتم عقد مؤتمر صحفي للإجابة على الأسئلة حول الحادثة وآثارها.

Information Security Incident Response Procedure
(Internal / Restricted) داخلي / مقيد

المتحدثون الرسميون المعتمدون للبنك:

(NAME) الاسم	(ROLE) الدور	(INCIDENT SCALE) مقياس الحادثة
A شخص	للاتصالات IRT عضو	منخفض
B شخص	رئيس الاتصال المؤسسي	متوسط
C شخص	الرئيس التنفيذي	عالي

Table 4: Media spokespeople

سيعتمد المتحدث الأنسب على حجم الحادثة وتأثيرها على العملاء والموردين والجمهور وأصحاب المصلحة الآخرين.

6 احتواء الحوادث، القضاء عليها، التعافي منها وإشعار الجهات المعنية (Incident containment, eradication, recovery and notification)

يصف هذا القسم الخطوات الرئيسية المتضمنة في إدارة الحادثة.

6.1 الاحتواء (Containment)

ستكون الخطوة الأولى هي محاولة إيقاف الحادثة من أن تصبح أسوأ، أي احتوائها. في حالة تفشي فيروس، قد يستلزم ذلك فصل الأجزاء المتأثرة من الشبكة؛ بالنسبة لهجوم قرصنة، قد يشمل تعطيل ملفات تعريف أو منافذ معينة على جدار الحماية أو ربما فصل الشبكة الداخلية عن الإنترنت تماماً.

ملاحظة: إذا تم الحكم بأنه من المحتمل أن تكون الأدلة الرقمية بحاجة إلى جمعها والتي سنستخدم لاحقاً في المحكمة، فيجب اتخاذ الاحتياطات لضمان أن تظل هذه الأدلة مقبولة.

المبادئ الأربعة الرئيسية للأدلة الرقمية:

المبدأ	الوصف
المبدأ 1	لا تغير أي بيانات. إذا تم فعل أي شيء يؤدي إلى تغيير البيانات على النظام ذي الصلة بأي شكل من الأشكال، فإن هذا سيؤثر على أي قضية محكمة لاحقة.
المبدأ 2	الوصول إلى البيانات الأصلية فقط في ظروف استثنائية. سيستخدم متخصص مدرب أدوات لأخذ نسخة بت من أي بيانات محفوظة في الذاكرة.
المبدأ 3	حافظ دائماً على مسار تدقيق لما تم القيام به.
المبدأ 4	يجب على الشخص المسؤول ضمان اتباع الإرشادات.

قبل وصول متخصص، يجب جمع المعلومات الأساسية:

- صور فوتوغرافية أو مقاطع فيديو للرسائل أو المعلومات ذات الصلة
- سجلات مكتوبة يدوياً لتسلسل زمني للحادثة
- المستندات الأصلية، بما في ذلك سجلات من وجدها وأين ومتى
- تفاصيل أي شهود

بمجرد جمعها، سيتم الاحتفاظ بالأدلة في مكان آمن حيث لا يمكن العبث بها وإنشاء سلسلة حيازة رسمية..

6.2 القضاء على الحوادث (Eradication)

يجب أن تمر إجراءات إصلاح الضرر الناجم عن الحادثة، مثل حذف البرمجيات الخبيثة، عبر عملية إدارة التغيير (على الأرجح كتغيير طارئ).

6.3 التعافي (Recovery)

خلال مرحلة التعافي، يجب استعادة الأنظمة إلى حالتها قبل الحادثة، على الرغم من أنه يجب بعد ذلك تنفيذ الإجراءات اللازمة لمعالجة أي نقاط ضعف تم استغلالها كجزء من الحادثة. قد يشمل ذلك أنشطة مثل تثبيت التصحيحات وتغيير كلمات المرور وتقوية الخوادم وتعديل الإجراءات.

6.4 الإشعار (Notification)

إخطار حادثة أمن المعلومات وما ينتج عنها من فقدان البيانات هو مسألة حساسة يجب التعامل معها بعناية وبموافقة إدارية كاملة.

سيقدر IRT ، بناءً على المشورة القانونية والخبراء الآخرين وبفهم كامل لتأثير الحادثة، ما هو الإخطار المطلوب ومتى يجب أن يحدث والشكل الذي سيتخذه.

بنك الأفاق الرقمية سيمثل دائماً بالكامل للمتطلبات القانونية والتنظيمية المعمول بها فيما يتعلق بإخطار الحوادث وسيقيم بعناية أي عروض سنقدم للأطراف التي قد تتأثر بالحادثة، مثل خدمات مراقبة الائتمان.

7 نشاط ما بعد الحادثة (Post-incident activity)

سيقرر قائد الفريق، بناءً على أحدث المعلومات من ضابط الاتصال بالحادثة وأعضاء الفريق الآخرين، النقطة التي يجب عندها وقف أنشطة الاستجابة وإيقاف IRT.

هذا القرار سيكون وفقاً لتقدير قائد الفريق ولكن يجب أن يستند إلى المعايير التالية:

المعيار	الوصف
تم حل الموقف بالكامل أو أنه مستقر بشكل معقول	—
تباطأ وتيرة تغير الموقف	إلى نقطة حيث لا يُطلب سوى عدد قليل من القرارات
الاستجابة المناسبة جارية بالفعل وخطط التعافي تتقدم وفقاً للجدول الزمني	—
انخفضت درجة المخاطر على البنك إلى نقطة مقبولة	—
تم الوفاء بالمسؤوليات القانونية والتنظيمية الفورية	—

إذا كان التعافي من الحادثة مستمراً، يجب على قائد الفريق تحديد الإجراءات التالية التي يجب اتخاذها:

الوصف	الإجراء
مثلاً أسبوعية حسب الظروف	IRT اجتماعات أقل تكراراً لـ
—	يتوقف IRT إبلاغ جميع الأطراف المعنية بأن
—	ضمان تأمين جميع وثائق الحادثة
—	طلب من جميع الموظفين غير المشاركين في العمل الإضافي العودة إلى واجباتهم العادية

بعد أن يتم توجيه IRT بالتوقف، سيعقد قائد الفريق جلسة استماع لجميع الأعضاء، ويفضل أن يكون ذلك في غضون 24 ساعة. سيتم فحص سجلات الحادثة ذات الصلة من قبل IRT للتأكد من أنها تعكس الأحداث الفعلية وتمثل سجلاً كاملاً ودقيقاً للحادثة.

سيتم عقد مراجعة أكثر رسمية لما بعد الحادثة في وقت يقرره كبار الإدارة وفقاً لحجم وطبيعة الحادثة.

8 جهات الاتصال الخارجية المفيدة (Appendix B: Useful external contacts)

يجب استخدام الجدول أدناه لتسجيل الاتصالات الأولية الناجحة وغير الناجحة مع أعضاء فريق الاستجابة للحوادث (IRT).

الاسم	الدور في الخطة	رقم المكتب	رقم المنزل	رقم الجوال	التاريخ / الوقت	النتيجة	وقت الوصول المتوقع (إن تم الاتصال)
سارة الحربي	(Team Leader) قائد الفريق	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
فهد العتيبي	(Team Facilitator) ميسر الفريق	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
مدير حوكمة أمن المعلومات	(Team Leader Deputy) نائب قائد الفريق	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
مدير SOC	ضابط اتصال الحوادث (Incident Liaison)	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
مدير البنية التحتية	تقنية المعلومات (Information Technology)	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
مدير العمليات المصرفية	العمليات التشغيلية (Business Operations)	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
مدير المرافق	(Facilities Management) إدارة المرافق	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
مسؤول الصحة والسلامة	(Health and Safety) الصحة والسلامة	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
خالد الشمري	(Human Resources) الموارد البشرية	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
مدير استمرارية الأعمال	تخطيط استمرارية الأعمال (Business Continuity Planning)	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
مدير التسويق	الاتصالات (العلاقات العامة ووسائل الإعلام) (Communications [PR and Media Relations])	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—
ليلى الدوسري	الشؤون القانونية والتنظيمية (Legal and Regulatory)	011-XXX-XXXX	—	05X-XXX-XXXX	—	—	—

ملاحظة: للأرقام الفعلية، يتم تعبئتها من قبل البنك. القالب يطلب فقط الأسماء والأدوار.

Information Security Incident Response Procedure (Internal / Restricted) داخلي / مقيد

Table 5: Initial response contact sheet

Appendix B: Useful external contacts 9

تُستخدم الجدول أدناه لعرض تفاصيل الاتصال بالجهات الخارجية التي قد تكون مفيدة بناءً على طبيعة الحادثة:

(Organization) الجهة / المنظمة	(Contact) جهة الاتصال	(Telephone Number) رقم الهاتف	(Email Address) البريد الإلكتروني
البنك المركزي السعودي (ساما)	إدارة الأمن السيبراني	XXXXXXXXXX	XXXX@sama.gov.sa
(NCA) الهيئة الوطنية للأمن السيبراني	فريق الاستجابة للطوارئ	XXXXXXXXXX	XXXX@nca.gov.sa
(SDAIA) هيئة البيانات والذكاء الاصطناعي	إدارة حماية البيانات	XXXXXXXXXX	XXXX@sdaia.gov.sa
(STC) شركة الاتصالات السعودية	الدعم الفني للإنترنت	XXXXXXXXXX	XXXX@stc.com.sa
(مزود الخدمة السحابية) AWS	دعم الأمن	XXXXXXXXXX	—
شركة التدقيق الأمني الخارجي	مدير المشروع	XXXXXXXXXX	—
شركة التأمين السيبراني	إدارة المطالبات	XXXXXXXXXX	—
مستشار التحقيق الجنائي الرقمي	—	XXXXXXXXXX	—
شرطة الرياض (الجرائم الإلكترونية)	—	999	—
الدفاع المدني	—	998	—

Table 6: Useful external contacts

10 جدول أعمال اجتماع فريق الاستجابة للحوادث القياسي (Appendix C: Standard) (incident response team meeting agenda)

يوصى بأن يتم استخدام جدول الأعمال القياسي التالي لاجتماعات فريق الاستجابة للحوادث.

جدول الأعمال (AGENDA)

الحضور : جميع أعضاء فريق الاستجابة للحوادث

الموقع : مركز القيادة / غرفة الحرب / اجتماع عبر الإنترنت

التكرار : كل أربع ساعات

الرئيس : قائد الفريق

محضر الاجتماع: منسق الفريق

1. الإجراءات من الاجتماع السابق
2. تحديث حالة الحادثة
3. القرارات المطلوبة
4. تخصيص المهام
5. الاتصالات الداخلية
6. الاتصالات الخارجية
7. إيقاف الاستجابة
8. أي أعمال أخرى